

Anatomía del BAA

Lo que tu healthtech firma al vender a
clínicas US

Fernando Hurtado

Fractional CISO · AI Governance

Sin BAA, no le vendes a un hospital de Estados Unidos.

El Business Associate Agreement es el contrato que te obliga a proteger la información de salud (PHI) de los pacientes de tu cliente. No es papeleo legal: es una lista de controles operativos que tienes que poder demostrar.

Qué te obliga a hacer

- 1 Uso de PHI:** solo para lo que dice el contrato. Trampa: features nuevos que tocan PHI sin actualizar el BAA.
- 2 Safeguards técnicos:** cifrado, accesos y logging sobre PHI. Trampa: controles 'en general', no específicos a PHI.
- 3 Sub-BAAs:** tu proveedor de LLM y tu hosting también lo necesitan. Trampa: olvidar que el modelo es sub-procesador.

Cuando algo falla

- 1 Breach notification:** avisar en plazos definidos (días, no semanas). Trampa: no poder detectar el breach a tiempo.
- 2 Terminación y retorno:** devolver o destruir la PHI al terminar. Trampa: PHI regada en logs y backups sin mapear.

3 errores al negociar

- 1 Firmar el BAA estándar del hospital sin leer las cláusulas de indemnización.
- 2 Prometer controles que aún no tienes operando.
- 3 Ignorar que tu stack de IA es un sub-procesador de PHI.

EL PATRÓN

El BAA describe la operación que deberías tener — no la que prometes tener.

Antes del primer BAA

Minimum viable HIPAA pack

- 1** **Políticas** de privacidad y seguridad de PHI, aprobadas.
- 2** **Controles técnicos** sobre PHI: cifrado, accesos, logging.
- 3** **Inventario** de proveedores que tocan PHI, con sus BAAs.

EL RESULTADO

Llegas a la mesa con la operación lista, no con promesas.

¿Tu healthtech está cerca de su primer BAA con un cliente US?

Guarda esta anatomía. Educativo, no sustituye revisión legal — revisa tu BAA con un abogado.

cal.com/fernando-hurtado

Fernando Hurtado

Fractional CISO · AI Governance